CONFIDENTIAL

SOCIAL ENGINEERING ASSESSMENT

Final Report

Client	Brightwater Logistics Ltd.
Engagement reference	BW-SE-2026-014
Prepared by	[Tester Company]
Report version	v1.0 (Final)
Report date	Friday, 2 October 2026

Classification: CONFIDENTIAL. Restricted distribution (see Document Control).

Document control

Item	Detail
Client	Brightwater Logistics Ltd. (the "Client")
Tester	[Tester Company] (the "Tester")
Engagement type	Authorized social engineering assessment: phishing, technical email checks, MFA test-account checks, help desk (voice) testing, and physical entry testing at one owned site
Authorization	Master Services Agreement and Statement of Work signed 25 August 2026; Rules of Engagement (RoE) v1.2 signed 9 September 2026; authorization letter issued 9 September 2026
Testing window	Tuesday 15 September 2026, 08:00 UTC, to Friday 18 September 2026, 17:00 UTC (Client local time is UTC+1). Activity took place Tuesday to Thursday; Friday was held as a buffer and no testing took place
Time convention	All times in this report are UTC unless stated otherwise
Report status	Final, issued after sponsor fact-check of the 25 September draft
Classification	Confidential

Distribution (named roles only)

Role	Receives
Executive sponsor (Chief Information Security Officer)	Full report
Engagement owner (Head of IT Security)	Full report
General Counsel	Full report
Chief Executive Officer	Sections 1, 3, and 8
Chief Financial Officer	Sections 1, 3, 8, and Finding F-04
Head of HR	Sections 1, 2, 3, and 8
Head of Facilities	Sections 1, 3, 8, and Findings F-07 and F-08
SOC Lead, IAM Lead, Head of Service Desk	Full report

Please do not forward this report outside the list above without the sponsor's approval. It describes weaknesses that a real attacker could use.

Version history

Version	Date	Change
v0.1	23 September 2026	Internal draft, second-tester review
v0.9	25 September 2026	Draft to sponsor for fact-check (dates, scope, wording)
v1.0	2 October 2026	Final after fact-check; no conclusions changed

Authors and reviewers (roles)

Role	Responsibility
Lead tester	Planning, live testing, analysis, report author
Second tester	Live testing, pretext review, independent check of all figures
Quality reviewer (not on the engagement)	Review of method, wording, and data protection

How to read this report

If you are...	Read	Time
An executive	Section 1 (Executive summary), Section 3 (What worked well), Section 8 (Recommendations roadmap)	15 minutes
In IT, security, or the SOC	Everything; start with Sections 4, 6, and 7	60 minutes
In HR, legal, or communications	Sections 1, 2, and 3, plus Appendix F (staff message)	20 minutes
In Facilities	Sections 1, 3, 8 and Findings F-07 and F-08	15 minutes

Three things to keep in mind while reading:

1. **This report is about systems and processes, not people.** No individual is named or identifiable. Every result is a group figure. Where a group is too small to report safely, the figure is shown as a band or as "fewer than 5".
2. **A "failure" here means a control gap.** When we write that a message "reached the submission step", we are describing what the surrounding controls allowed, not a judgment about the people involved.
3. **More people reported than submitted.** That is the most important positive result in this report and it is explained in Section 3.

1. EXECUTIVE SUMMARY

Why we tested

Brightwater Logistics asked [Tester Company] to measure how well its technology, procedures, and people work together against realistic social engineering attempts. The Client stated the decisions that the results should inform:

1. Whether to invest in phishing-resistant sign-in (security keys or passkeys).
2. Whether to redesign the help desk identity verification procedure and its outsourcing terms.
3. Whether to improve the way suspicious messages are reported and handled.

This is the Client's first measured baseline. No comparable earlier results were available.

What we tested

Area	What we did	Scale
Phishing (people)	Wave 1: realistic test email with messages allowed through filters, to measure human behavior	296 recipients
Phishing (technology)	Wave 2: different realistic test email, **not** allowed through filters, to measure technical controls and behavior	298 recipients
Email authentication check	Spoofed messages using the Client's own domain sent to Client-owned test mailboxes	10 test messages
Sign-in (MFA) check	Relay-style sign-in test on Client-provided **test accounts** only	4 test accounts
Help desk (voice)	Scripted calls to the outsourced help desk using Client test accounts	10 calls
Physical entry	Entry attempts at the owned headquarters (HQ) building	6 attempts over 3 days

Headline results (all figures are group totals)

1. **Reporting beat submitting.** Across both phishing waves, **13.7 percent** of delivered messages were reported (71 of 518) while **6.2 percent** led to a submission event (32 of 518). **83 percent** of reporters (59 of 71) reported without first clicking.
2. **Technical filtering stopped about one in four unassisted messages.** In the wave without allow-listing, the email gateway blocked **23.8 percent** (71 of 298) and **75.5 percent** reached inboxes.
3. **Sign-in methods could be completed on a look-alike page, and nobody was alerted.** On 3 of 4 test accounts, a relayed sign-in succeeded. Only the account using a security key withstood it. The SOC raised **no alert** on any of the 3 successful test sign-ins.
4. **The help desk procedure was followed fully on 4 of 10 calls.** When the caller could not complete verification, a password or MFA reset was nevertheless performed on **4 of 10** calls (all on test accounts).
5. **One of six physical attempts reached the finance-floor target.** The main-entrance turnstile blocked one attempt and staff challenged two. The one that succeeded followed a staff member through a badge-controlled door and was not challenged for 41 minutes.

What worked well

- More recipients reported than submitted, and the first report arrived **4 to 6 minutes** after delivery.
- The SOC acknowledged the first report within **3 to 5 minutes** and removed the message from every mailbox on both days.
- Email authentication on the Client's own domain stopped **10 of 10** spoofed test messages.
- A security key on a test account **blocked** the relayed sign-in.
- The HQ turnstile and the floor 3 stairwell badge reader both held.
- Where staff performed the callback step on the help desk, **no** reset was performed (4 of 4 calls).

The three control gaps that matter most

#	Control gap (plain language)	Related findings
1	**Sign-in security and sign-in monitoring.** Passwords plus common MFA methods can be completed on a fake page, privileged-style accounts still use SMS codes, and unusual sign-ins raise no alert	F-01, F-02
2	**Help desk verification.** The written procedure is not enforced by the process itself, there is no notification to the user after a reset, and the outsourcing contract does not measure adherence	F-04, F-11
3	**Early warning and containment.** Reporting is not available in the same way on every device, and removal of a reported message is manual and took 34 to 52 minutes, during which roughly 70 percent of clicks occurred	F-05, F-03, F-06

A fourth area, **physical access at restricted doors** (F-07, F-08), is important for the finance floor and is covered in the roadmap.

Findings by rating

Rating	Count	Findings
Critical	2	F-01, F-04
High	4	F-02, F-03, F-05, F-07
Medium	4	F-06, F-08, F-09, F-11
Low	1	F-10
Total	**11**	

Top recommendations for the next 30 days

#	Action	Owner (role)
1	Replace SMS codes for privileged and finance accounts with security keys; turn on number matching and sign-in context for all push approvals	IAM Lead
2	Turn on risk-based sign-in alerts (new country, repeated prompts, new mailbox rules, new app consent) and give the SOC a runbook for them	SOC Lead

#	Action	Owner (role)
3	Publish an enforced one-page help desk verification procedure: callback to the number on file, manager approval for MFA changes, notification to the user's other channels after any reset	Head of Service Desk
4	Put the report button on every mail client (desktop, web, mobile) and set a triage-to-removal target of 30 minutes	Email admin and SOC Lead
5	Announce a signed no-blame reporting policy and thank reporters, in aggregate	CEO and Head of HR

Important notes

- **No individual results are included in this report or held by the Tester in an identifiable form.** The contract and RoE commit the Client not to use results to discipline or identify any person, and we ask that managers not request individual information.
- **No real credentials were captured or stored.** The landing pages recorded events only. The method was verified before launch (Appendix C) and disclosed in Section 9.
- **The Client's people are not the weakest link in this report.** The weakest points are controls that depend on one person getting every decision right under pressure.

2. SCOPE AND METHOD

2.1 Authorization and governance

Item	What was in place
Signer authority	The MSA and SOW were signed by the Chief Financial Officer under a delegation-of-authority letter that was independently verified (registry lookup, call-back to the main switchboard number, signature trail). The CISO co-signed the RoE as executive sponsor
Four Ownership Questions	**Employer:** Brightwater Logistics Ltd. for all in-scope staff. **HQ building:** owned by the Client. **Regional Office:** leased. **Help desk:** outsourced to a vendor
Authorization letter	Signed by the CFO; two 24/7 emergency contacts named and tested by a live call and a dry run on 10 September
Stop word and verification word	Set on 8 September, shared only with named people, tested on 10 September. Not used during the engagement
Employee representatives	The staff forum was consulted on 2 September; it asked for group-only reporting, which is built into this report
Insurance	Tester's professional indemnity and cyber cover confirmed to include on-site and social engineering work; certificate supplied to the Client
Legal review	Client General Counsel reviewed the RoE, pretexts, and data handling; Tester counsel reviewed call recording and personal data handling

Third parties

Third party	Outcome
Help desk vendor	Written consent from the vendor's authorized signer received 8 September; vendor's account manager aware, front-line agents not told
Landlord of the Regional Office	**Consent was not received before the testing window.** The Regional Office was therefore **excluded** from all physical testing. No physical testing took place there
Email provider	Provider's current security-testing policy reviewed; advanced-delivery configuration used for Wave 1 only
Email security gateway	Allow-listing configured for Wave 1 and **deliberately not** configured for Wave 2
Building security (HQ guards)	Guard contractor notified that a test might occur, with no dates, no scope detail, and an agreed escalation contact
SMS and telephony	Not applicable (SMS was out of scope); a registered voice line was used for help desk calls
Regulator	Not applicable to this engagement

2.2 Objectives

Primary goal. We wanted to learn how recipients and technical controls respond to realistic phishing, and whether the help desk verification procedure holds under mild time pressure, so that the Client can decide on sign-in security, help desk procedure, and reporting investments. This was measured by report rate, click rate, submission rate, time to report, and time to containment across two phishing waves of about 300 recipients each, and by verification adherence across 10 scripted help desk calls.

Secondary goals.

1. Test whether an unbadged person can reach the finance floor at HQ (entry success, challenge rate, depth reached).
2. Check whether the Client's own domain can be spoofed (technical check).

2.3 Scope

In scope

Activity	Conditions
Email phishing, two waves, different pretexts	Approved pretext cards only; allow-list decision recorded per wave; events-only landing pages; no real credential capture
Spoof check of the Client's own domain	Delivered only to 10 Client-owned test mailboxes
Sign-in (MFA) relay check	**Client-provided test accounts only**, run with a Client trusted agent; sessions revoked afterward
Voice calls to the outsourced help desk	Client test accounts only; one script; no recording; two testers on every call
Physical entry attempts at HQ	Business hours; authorization letter carried; flag method for proof; no force, no tools
Passive open-source research (OSINT)	Public sources only; role-level data only

Out of scope (and not performed)

Activity	Reason
SMS, QR code, and USB or media drops	Not requested
Business email compromise or payment-change simulation	Not requested; recommended for the next engagement (see Section 9)
Physical testing at the Regional Office	Landlord consent not received
Executives, board members, SOC and IT security staff	Excluded by the sponsor (see below)
Contractors and temporary staff	Employed by an agency; no agency consent
After-hours physical testing	Not requested
Anything involving real employee accounts at the help desk	Test accounts only
Recording of audio or video	Not permitted by the RoE

Activity	Reason
Impersonating police, regulators, emergency services, or any real named person	Excluded by the RoE

2.4 Target pool

Item	Value
Total employees	640
Excluded: executives and board	18
Excluded: SOC and IT security staff	8
Excluded: staff on leave	14
Excluded: staff flagged by HR (for example, active HR processes)	6
Total excluded	**46**
Eligible for phishing	**594**
Wave 1 random sample	296
Wave 2 random sample (different people from Wave 1)	298
Contractors and temps (not in scope)	31

Notes on how the pool was built:

1. The Client exported work email addresses, roles, and departments only. No home addresses, personal numbers, or HR records were requested or received.
2. Each person received a random ID. The key linking IDs to people is held encrypted by two named testers only.
3. The two waves used **different people** so that the second message was not affected by the first.
4. The list was locked on 11 September. No changes were made during the testing window.

2.5 Techniques and pretexts

Pretext ID	Channel	Summary (no wording reproduced)	Target	Risk	Allow-listed?
P-01	Email	Routine "shared document" notification matching an ordinary collaboration workflow	Wave 1 sample (296)	Low	Yes
P-02	Email	Routine IT "mailbox storage" notice, sent from a newly registered look-alike domain	Wave 2 sample (298)	Low	No
P-03	Voice	A traveling colleague who cannot reach their usual sign-in method asks for help; mild time pressure, no emotional claims	Outsourced help desk	Medium	n/a
P-04	Physical	A courier delivering a parcel to a named department	HQ reception	Medium	n/a
P-05	Physical	A contractor arriving to service shared office equipment	HQ side entrance	Medium	n/a

All five pretext cards were written by one tester, reviewed by a second tester, reviewed by HR and legal for tone and topic, and approved in writing by the sponsor between 8 and 9 September. No pretext was changed during the engagement. None used pay, layoffs, bonuses, health, family matters, real incidents, or any government or emergency authority (full summaries in Appendix A).

Phish difficulty

We rated each phishing message before sending, using the approach of the NIST Phish Scale (the number of detectable cues in the message and how well the story fits a recipient's normal work).

Pretext	Detectable cues	Fit with recipients' work	Difficulty rating
P-01	5	High	Moderately difficult to detect
P-02	9	Moderate	Less difficult to detect

Results from P-01 and P-02 should **not** be compared directly as a trend. They differ in difficulty, in allow-listing, and in the people tested.

2.6 Need-to-know circles and SOC design

Circle	Who (roles)	What they knew
1: Control team	CISO, Head of IT Security, General Counsel	Everything
2: Safety net	Head of HR, Head of Facilities, two 24/7 emergency contacts	Dates, scope, escalation, stop word
3: Deconfliction	IT Security Manager	Sender indicators (domains, addresses), but **not** timing or targets
4: Everyone else	All other staff, including the SOC analysts	Nothing until the staff message on 21 September

Blind SOC design. The SOC analysts were not told, so that real detection and response could be measured. The deconfliction rule was: the Circle 3 contact informs the SOC lead 60 minutes after the first report or immediately if any external party is about to be notified, whichever comes first. This took place after containment on both days, and no external notification occurred.

2.7 Ethics and data handling commitments (and how we kept them)

Commitment	What we did
No discipline	Contract clause 14 and RoE section 16 signed; HR confirmed in writing that individual results will not enter personnel records
Group-only reporting	Minimum reportable group of 10 recipients; department figures shown as bands; counts under 5 shown as "fewer than 5"
No credential capture	Landing pages recorded events only; verified with a canary test (Appendix C)
Minimal personal data	OSINT log: 62 items recorded; 44 organization-level, 13 role-level, and 5 personal items **deleted immediately without use**
No recording	No audio or video was recorded

Commitment	What we did
No contact with real emergencies or sensitive topics	None occurred; see Section 9 for the one personal reply received and how it was handled
Retention	Pseudonym key destroyed by 30 October 2026; raw logs and evidence deleted by 30 November 2026; deletion confirmation will be sent to the sponsor

2.8 How results are measured

The full method is in Appendix C. The key points:

1. **Denominators are stated for every rate.** Rates for phishing use **delivered** messages.
2. **Scanner clicks were removed.** Security scanners often click every link within seconds. Clicks within 5 seconds of delivery from the gateway's scanner ranges, or that hit several links at once, were excluded. Raw and cleaned numbers are both shown.
3. **Each person is counted once** per measure.
4. **Open rates are not used.** Image preloading makes them unreliable.
5. **Margins of error** are about ±6 percentage points for Wave 1 (293 delivered), ±7 for Wave 2 (225 delivered), and ±4 for the two waves combined (518 delivered). Differences smaller than these are likely to be noise.
6. **Where the Client could provide timestamps** (SOC ticket, triage, and message removal), we merged them with our own log, with permission.

2.9 Engagement schedule

Phase	Dates (2026)	Status
Contract and RoE signed	25 Aug to 9 Sep	Done
Kickoff meeting	Thu 27 Aug	Done
Third-party consents	28 Aug to 8 Sep	Done (Regional Office landlord outstanding; excluded)
Passive OSINT (time-boxed to two days)	31 Aug to 1 Sep	Done
Staff forum consulted	Wed 2 Sep	Done
Infrastructure build and pre-launch checks	2 to 10 Sep	Done
Pretext approval	8 to 9 Sep	Done
Dry run, stop-word test	Thu 10 Sep	Done
Go / no-go meeting	Fri 11 Sep	**Go**
Live testing	Tue 15 to Thu 17 Sep	Done
Buffer day	Fri 18 Sep	No testing
Teardown and staff message	21 to 23 Sep	Done
Draft to sponsor for fact-check	Fri 25 Sep	Done

Phase	Dates (2026)	Status
Final report	Fri 2 Oct	This document
Debrief meeting	Tue 6 Oct	Scheduled

3. WHAT WORKED WELL

A test like this is only useful if the Client also learns **what is worth protecting**. Every item below is measured and specific.

3.1 People and reporting

Observation	Evidence
More recipients reported than submitted	Combined: 71 reports (13.7 percent) versus 32 submission events (6.2 percent). Wave 1: 38 reports (13.0 percent) versus 21 submissions (7.2 percent). Wave 2: 33 reports (14.7 percent) versus 11 submissions (4.9 percent)
Most reporters reported **without** clicking	59 of 71 reporters (83.1 percent) reported before any click; 31 of 38 in Wave 1 (81.6 percent) and 28 of 33 in Wave 2 (84.8 percent)
Reports arrived quickly	First report after **6 minutes** (Wave 1) and **4 minutes** (Wave 2); median time to report 19 and 15 minutes
Colleagues warned each other	IT observed at least 6 internal chat warnings within the first hour of Wave 1 and at least 9 within the first hour of Wave 2 (counts supplied by IT; no messages were read by the Tester)
Two groups reported at roughly twice the company rate	Finance and IT (non-security) groups both reported at 20 to 25 percent, compared with about 13.7 percent overall (group sizes are small; see the department table in Section 4). **We recommend the Client find out what these teams have in common and spread it**

3.2 Technical controls

Control	Evidence
Email authentication on the Client's own domain	**10 of 10** spoofed test messages claiming the Client's domain were rejected (DMARC policy at "reject")
Email gateway	Blocked or quarantined **71 of 298** unassisted Wave 2 messages (23.8 percent)
Report button (desktop)	Used for 46 of 71 reports (64.8 percent)
Security keys	The test account with a security key **withstood** the relayed sign-in; the sign-in could not be completed
Number matching (pilot)	On the pilot test account, a blind approval of an unsolicited prompt was prevented; see F-01 for its limits

3.3 Response

Observation	Evidence
The SOC acted on reports quickly at the start	Ticket opened **5 minutes** (Wave 1) and **3 minutes** (Wave 2) after the first report
The SOC completed removal on both days	The message was removed from every mailbox that received it
The SOC improved between waves	First report to complete removal fell from **52 minutes** to **34 minutes**

Observation	Evidence
Security responded fast to a physical report	A guard reported one entry attempt and security responded in **9 minutes**

3.4 Process and physical controls

Control	Evidence
Callback step on the help desk	**4 of 4** calls where the agent completed the callback step ended with **no** reset performed
HQ turnstile	Blocked 1 of 1 tailgating attempt at the main entrance
Floor 3 stairwell badge reader	Held on the one attempt made at that door
Staff challenge behavior	Two attempts were challenged within **4** and **11 minutes**; both challenges were polite, asked for a badge, and led to an escort to reception
Badge display	Of 140 people observed entering the main entrance over three days, **118 (84 percent)** displayed a visible badge inside (observation counts only; nobody was identified)

3.5 Why these positives matter

Reporting is the Client's **best early-warning system**, and it works. Faster removal, a button on every device, and feedback to reporters would make a good system much better. We recommend the Client **protect and measure** these strengths (see roadmap items R-05, R-06, and R-12) so that they are not lost.

4. RESULTS AT A GLANCE

4.1 Summary by technique

Each attempt receives one outcome. "Reported" is a subset: someone who reported may also appear under "Partial" or have taken no other action.

Technique	Attempts	Blocked by technology	Stopped or reported by people	Partial	Reached objective	Not completed
Phishing, Wave 1 (allow-listed)	296 recipients	Not applicable (allow-listed)	38 reported	26 clicked, no submission	21 submission events	3 undelivered or removed
Phishing, Wave 2 (not allow-listed)	298 recipients	71 blocked or quarantined	33 reported	18 clicked, no submission	11 submission events	2 bounced
Spoof of Client's own domain	10 test messages	10 rejected	0	0	0	0
Sign-in relay check (test accounts)	4 accounts	1 (security key)	0	0	3 sign-ins completed	0
Help desk calls	10 calls	0	4 refused after full verification; 3 reported	2 ended with no action and no escalation	4 resets performed	0
Physical entry (HQ)	6 attempts	1 (turnstile)	2 challenged; 1 reported	2 reached staff areas then stopped	1 reached the finance-floor flag	0

Definitions. "Reached objective" means the test objective was met (a submission event, a completed sign-in on a test account, a performed reset on a test account, or a flag reached). It does not describe a failure of any person. "Partial" means the attempt progressed but did not meet the objective.

4.2 Phishing results

4.2.1 Wave 1 (P-01, allow-listed, moderately difficult)

Allow-listing was used so that the test measured **people**, not filters.

Measure	Count	Rate	Denominator	Note
Sent	296			
Undelivered or removed	3	1.0% of sent	Sent	2 bounces; 1 removal (see D-002)
Delivered	293	99.0% of sent	Sent	

Measure	Count	Rate	Denominator	Note
Click events, raw (recipients with at least one click)	74	25.3%	Delivered	Includes security scanners
Scanner-attributed clicks removed	27			Rule in Appendix C
Human unique clicks	**47**	**16.0%**	Delivered	Margin of error about ±6 points
Submission events	**21**	**7.2%**	Delivered	Events only; no content captured
Click to submission ratio		44.7% (21 of 47)	Clicks	
Reports	**38**	**13.0%**	Delivered	
Reported before any click	31	81.6% of reporters	Reporters	
Reported after a click	7	18.4% of reporters	Reporters	

```
WAVE 1 FUNNEL (allow-listed)

 Sent                      296  (100%)
  |
  v
 Delivered                 293  ( 99.0% of sent)
  |
  v
 Human click                47  ( 16.0% of delivered)
  |
  v
 Submission event           21  (  7.2% of delivered)

 Reported (any stage)       38  ( 13.0% of delivered)
```

4.2.2 Wave 2 (P-02, not allow-listed, less difficult)

No allow-listing was used so that the test measured **technical controls** as well as people.

Measure	Count	Rate	Denominator	Note
Sent	298			
Blocked or quarantined by the gateway	71	23.8%	Sent	Technology block rate
Bounced	2	0.7%	Sent	
Delivered to inboxes	**225**	**75.5% of sent**	Sent	
Click events, raw	47	20.9%	Delivered	Includes security scanners
Scanner-attributed clicks removed	18			
Human unique clicks	**29**	**12.9%**	Delivered	Margin of error about ±7 points
Submission events	**11**	**4.9%**	Delivered	Events only
Click to submission ratio		37.9% (11 of 29)	Clicks	
Reports	**33**	**14.7%**	Delivered	
Reported before any click	28	84.8% of reporters	Reporters	

Measure	Count	Rate	Denominator	Note
Reported after a click	5	15.2% of reporters	Reporters	

```
WAVE 2 FUNNEL (not allow-listed)

 Sent                      298  (100%)
  |
  |-- Blocked / quarantined  71  ( 23.8% of sent)
  |-- Bounced                 2  (  0.7% of sent)
  v
 Delivered to inboxes      225  ( 75.5% of sent)
  |
  v
 Human click                29  ( 12.9% of delivered)
  |
  v
 Submission event           11  (  4.9% of delivered)

 Reported (any stage)       33  ( 14.7% of delivered)
```

4.2.3 Both waves combined (context only)

The two waves had different difficulty, allow-listing, and recipients, so the combined figures are given for orientation and should not be used as a trend.

Measure	Count	Rate	Denominator
Delivered	518		
Human unique clicks	76	14.7%	Delivered
Submission events	32	6.2%	Delivered
Reports	71	13.7%	Delivered
Reported before any click	59	83.1% of reporters	Reporters
Margin of error (combined)		About ±4 points	

4.2.4 How people reported

Reporting route	Wave 1	Wave 2	Combined	Share
One-click report button	24	22	46	64.8%
Forwarded to the security mailbox	14	11	25	35.2%
Total reports	**38**	**33**	**71**	100%

IT confirmed that the report button is installed on the **desktop** mail client only. The forwarded reports are consistent with use of web or mobile clients (see F-05).

4.2.5 Raw versus cleaned clicks

Wave	Raw click rate	Cleaned (human) click rate	Difference
Wave 1	25.3%	16.0%	9.3 points removed as scanner activity
Wave 2	20.9%	12.9%	8.0 points removed as scanner activity

The gap is large, so we show both. Reports that quote raw click rates will overstate human clicks. The Client's gateway pre-fetches links even for allow-listed mail.

4.3 Results by department (bands, not rankings)

Departments are listed in **alphabetical order** and shown as bands to protect individuals and to avoid comparisons that the data cannot support. Margins of error for groups this small are large, so **differences between groups should not be read as ranking**. Only groups with at least 10 delivered recipients are shown. Smaller functions (Human Resources, Legal and Compliance, Facilities, and others) are combined as "Corporate functions".

Group	Delivered (both waves)	Approx. margin of error	Click rate band	Submission rate band	Report rate band
Corporate functions	59	±13 points	10 to 15%	0 to 5%	10 to 15%
Customer Service	84	±11 points	15 to 20%	5 to 10%	10 to 15%
Finance	37	±16 points	15 to 20%	5 to 10%	20 to 25%
IT (non-security)	24	±20 points	10 to 15%	0 to 5%	20 to 25%
Operations	157	±8 points	10 to 15%	5 to 10%	10 to 15%
Procurement and Supply Chain	40	±15 points	10 to 15%	0 to 5%	10 to 15%
Sales and Marketing	56	±13 points	15 to 20%	5 to 10%	10 to 15%
Warehouse and Depot Administration	61	±13 points	10 to 15%	0 to 5%	10 to 15%
All groups	**518**	**±4 points**	**14.7%**	**6.2%**	**13.7%**

How to use this table:

1. **For training design:** every group had both clicks and reports, which means the same messages that fooled some recipients were recognized by others in the same team. Practical, role-based examples will help every team.
2. **For learning:** two small groups (Finance, IT) reported at 20 to 25 percent. We recommend the Client ask those teams what helps them report (tools, habits, manager attitude) and share it.
3. **Do not use this table for performance management, targets, or comparison between managers.** The commitment in the RoE applies.

4.4 Spoof and email authentication check

Check	Result
Spoofed messages claiming the Client's own domain, sent from an unauthorized sender to 10 Client-owned test mailboxes	**10 of 10 rejected** at delivery
Published policy	SPF and DKIM in place; DMARC policy at "reject"
Look-alike domain registered 3 days before Wave 2	**Not** flagged or blocked on the basis of age or similarity (see F-03)

4.5 Sign-in (MFA) check on test accounts

All four accounts were created by the Client, mirror real configurations, and were operated with a Client trusted agent following a script. Sessions were revoked and accounts reset by the Client afterward. **No real employee account was used.**

Account	Profile	Sign-in method	Relayed sign-in	Repeated-prompt check	SOC alert
TA-1	Standard user	Authenticator push, no number matching	**Completed**	Second unsolicited prompt approved (scripted)	None
TA-2	Standard user, pilot group	Authenticator push with number matching	**Completed** (number shown on the fake page was entered)	Blind approval **not possible** (a number must be entered)	None
TA-3	Privileged-style role	SMS code	**Completed**	Not applicable	None
TA-4	Pilot group	Security key	**Blocked**	Not applicable	Not applicable (no sign-in)

Results: 3 of 4 sign-in paths could be completed through a relayed sign-in. 1 of 4 withstood it. For the 3 successful sign-ins, which came from the Tester's controlled infrastructure in a different country from the Client's offices, **no alert was raised in the following 24 hours** and no conditional access rule challenged or blocked them. Review with IT showed that risk-based sign-in policies are not enabled in the tenant.

4.6 Help desk results (voice)

Ten scripted calls were placed over two days to the outsourced help desk, using five Client test accounts (two calls per account). Six calls requested a password reset (medium risk) and four requested an MFA device reset (high risk). In every call the caller **could not** complete the verification fully (for example, no access to the usual sign-in method and no answer to a non-public question), which is the situation the procedure is designed to handle.

4.6.1 Outcomes

Outcome	Calls	Of which password-reset requests	Of which MFA-reset requests
Full verification followed; request refused	4	2	2
Request **not** performed, but no refusal script and no escalation (call ended)	2	1	1
Partial verification; restricted action **performed**	4	3	1
Total	**10**	**6**	**4**

Restricted action performed: **4 of 10 (40 percent)**; 3 of 6 password-reset requests (50 percent) and 1 of 4 MFA-reset requests (25 percent).

4.6.2 Adherence to the Client's written procedure

Required step	Done	Rate
Employee ID requested	10 of 10	100%
Callback to the number on file	4 of 10	40%
Verification question not answerable from public sources	5 of 10	50%
Manager approval requested (MFA-reset calls only)	1 of 4	25%
Ticket logged with verification evidence	8 of 10	80%
Restricted action **not** performed when verification was incomplete	6 of 10	60%
Suspicious call escalated or reported to security	3 of 10	30%
Notification sent to the user's other registered channels after a reset	0 of 4 resets	0%
All required steps followed	**4 of 10**	**40%**

4.6.3 Call length

Group of calls	Median call length
Full procedure followed (4 calls)	11 minutes
Ended with no action (2 calls)	7 minutes
Restricted action performed (4 calls)	5 minutes

The calls where the procedure was not completed were also the shortest. We recommend the Client review whether handle-time targets or call-queue pressure discourage the longer verification flow (see R-04).

4.7 Physical results (HQ only)

4.7.1 Attempts

Attempt	Day and time (UTC)	Method	Deepest zone reached	Outcome	Time to challenge
A1	Tue 15 Sep, 08:45	Following an entering person through the main turnstile	Lobby	**Blocked by technology** (turnstile)	Not applicable
A2	Tue 15 Sep, 11:20	Side entrance: followed a person through a door that was held open; then tried the floor 3 stairwell	Ground-floor staff corridor	**Partial.** Floor 3 stairwell badge reader held	Not challenged
A3	Wed 16 Sep, 08:55	P-04 (courier) at reception	Lobby	**Stopped by a person.** Receptionist verified the delivery with the named department, asked for a delivery slip, and told security	**4 minutes**

Attempt	Day and time (UTC)	Method	Deepest zone reached	Outcome	Time to challenge
A4	Wed 16 Sep, 13:10	P-04 (courier) at reception, different receptionist	Ground-floor mailroom corridor	**Partial.** Admitted after one phone call that confirmed a department name only; a staff member on floor 1 offered help and pointed to the lobby; tester left	Not verified
A5	Thu 17 Sep, 09:05	P-05 (contractor) at the side entrance	Floor 1	**Stopped by a person.** A staff member asked for a badge and escorted the tester to reception	**11 minutes**
A6	Thu 17 Sep, 13:30	Side entrance: followed a person through a door; then followed a staff member through the floor 3 badge door	**Floor 3 (restricted), flag location**	**Reached objective.** Flag photographed; no challenge for **41 minutes** on the floor; tester left	Not challenged

4.7.2 Rates

Measure	Result
Reached staff areas beyond reception	4 of 6 attempts (A2, A4, A5, A6): 66.7%
Reached the restricted finance floor flag	1 of 6: 16.7%
Challenged for a badge or verification	2 of 6: 33.3%
Median time to challenge	7.5 minutes (4 and 11)
Reported to security	1 of 6: 16.7%; security responded in **9 minutes**
Blocked by a physical barrier	2 of 6 (turnstile at A1; floor 3 stairwell badge reader at A2, which stopped progress)

4.7.3 Depth reached

Zone	Attempts
Lobby only	2 (A1, A3)
Ground-floor staff areas	2 (A2, A4)
Floor 1	1 (A5)
Floor 3 (restricted finance floor)	1 (A6)

4.7.4 Observations (counts only; nobody identified)

Observation	Result
Visible badge inside the building	118 of 140 people observed entering the main entrance over three days (84%)
Badge-controlled door held open for a following person	23 events observed across six hours of observation on floors 1 to 3

Observation	Result
Of those 23, the holder asked the follower to badge in	0 of 23

4.7.5 Evidence method

The flag for A6 was a marked, sealed envelope placed by the Client's trusted agent at an agreed spot on floor 3 before the test. The Tester photographed **the envelope only**, with no people, screens, or documents in the frame, and did not touch or remove anything.

4.8 Public information that made attacks easier (passive research)

Only public sources were used. The log recorded 62 items: 44 about the organization, 13 about roles, and 5 about individuals. The 5 personal items were deleted immediately without use.

What public information showed	Why it matters	Finding
Several recent job postings named specific products, including the email gateway and the MFA provider	Lets an attacker choose pretexts and tools that match the Client's stack	F-09
Public professional profiles showed team structure for Finance and Customer Service (counts and titles only were recorded)	Makes it easier to choose believable roles	F-09
Three company event photos on a public social page showed the badge design	Helps someone make a believable badge lookalike	F-09
Four of nine out-of-office auto-replies received during Wave 1 contained travel dates and the name of a delegate	Provides ready-made pretext details	F-10
Street imagery showed the side entrance used for A2, A5, and A6	Shows where staff routinely hold doors	F-07

5. TIMELINE

5.1 How to read the timeline

The timeline has three lanes: what the Tester did, which controls came into play, and what the Client did. All times are UTC. Each row is an event in the Tester's activity log merged with Client timestamps (Appendix B has the full log).

5.2 Overview timeline

Tuesday 15 September (Day 1)

TIME	TESTER ACTION	CONTROLS THAT ACTED	CLIENT RESPONSE
08:45	A1 tailgating attempt, main entrance	Turnstile stopped entry	(none)
09:00	Wave 1 emails begin (296)	Gateway scanned links (allow-listed; scanner pre-fetch seen)	(none)
09:02	First click recorded	No browser warning	(none)
09:06	First report received	Report button used	(none yet)
09:11	--	--	SOC ticket opened
09:33	--	--	SOC triage complete
09:40	--	--	Message removal begins (manual)
09:58	--	--	Message removed from all mailboxes
10:06	--	--	Deconfliction: Circle 3 contact informs SOC lead
11:20	A2 side-entrance attempt	Floor 3 stairwell badge reader held	(none)
11:30	--	--	HR tells engagement owner of a recipient on leave (D-002)

Wednesday 16 September (Day 2)

TIME	TESTER ACTION	CONTROLS THAT ACTED	CLIENT RESPONSE
08:55	A3 courier pretext, reception	Receptionist verified; guard reported	Security notified; response in 9 minutes
09:00	Wave 2 emails begin (298)	Gateway blocked 71 (23.8%); no external-sender cue	(none)
09:03	First click recorded	No browser warning	(none)
09:04	First report received	Report button used	(none yet)
09:07	--	--	SOC ticket opened
09:21	--	--	SOC triage complete
09:30	--	--	Message removal begins (manual)
09:38	--	--	Message removed from all mailboxes
10:04	--	--	Deconfliction call
13:10	A4 courier pretext, reception	Phone check confirmed a department name only	(none)
14:00 to 16:15	Help desk calls 1 to 5	Verification steps applied inconsistently	Tickets logged on 4 of 5

Thursday 17 September (Day 3)

```
TIME     TESTER ACTION                    CONTROLS THAT ACTED                 CLIENT RESPONSE
-----    -------------------------------  ---------------------------------   ---------------------------------
09:05    A5 contractor pretext, side      Staff challenge at 11 minutes       Escort to reception
         entrance
10:15 to Help desk calls 6 to 10          Callback used on some calls         Tickets logged on 4 of 5
12:30
13:30    A6 side entrance, then floor 3   Door held open by staff; no        (none during the 41 minutes)
                                          challenge
14:20    Sign-in relay check on TA-1 to   Security key blocked TA-4;          No SOC alert in the next 24 hours
         TA-4                             TA-1, TA-2, TA-3 completed
15:30    --                               --                                  Client revokes sessions and resets
                                                                              test accounts
```

Monday 21 September

The Client sent the all-staff debrief message (Appendix F) and the managers' briefing. Teardown of Tester infrastructure was completed by 23 September.

5.3 Time-to-event summary

Measure	Wave 1	Wave 2
First delivery	09:00	09:00
First click after delivery	2 minutes	3 minutes
First report after delivery	**6 minutes**	**4 minutes**
SOC ticket opened after first report	5 minutes	3 minutes
Triage complete after first report	27 minutes	17 minutes
Message removed from all mailboxes after first report	**52 minutes**	**34 minutes**
Median time to report (among reporters)	19 minutes	15 minutes
Human clicks that occurred before removal was complete	33 of 47 (70%)	20 of 29 (69%)
Submission events that occurred before removal was complete	15 of 21 (71%)	7 of 11 (64%)
Deconfliction call	10:06	10:04

What this tells the Client. Reporting began within minutes, but removal took 34 to 52 minutes, and roughly seven in ten clicks and submission events happened before removal finished. **The most effective lever on exposure is therefore the speed of removal, not only the number of reports.**